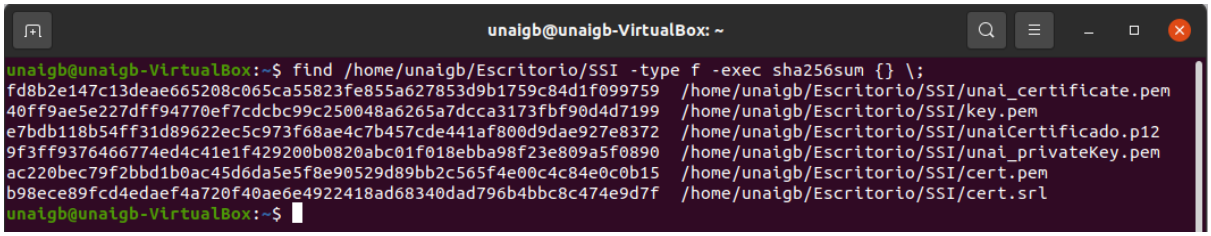
PRÁCTICA 6 - INTEGRIDAD Y CONTROL DE ACCESO

Realizado por Unai García Blanco y Alberto García Martín

1. Calcular la suma de algunas carpetas y/o ficheros.

Lo primero que vamos a hacer es calcular el resumen SHA256 de una carpeta que contiene ficheros de otras prácticas anteriores:



○ Cambiar el contenido de algún fichero e indicar cómo proceder para detectar la alteración.

Ahora vamos a proceder a cambiar el contenido de un fichero, y volveremos a ejecutar el find para buscar un cambio dado por la modificación. En este caso vamos a modificar el cert.srl añadiendo una línea más:

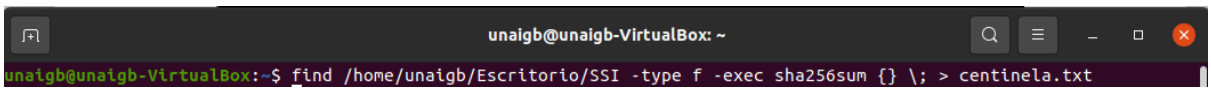


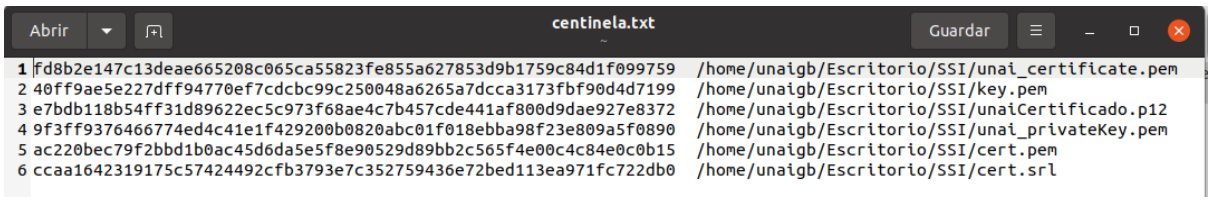
Y como se puede observar al comparar los dos hash mostrados, se ve el cambio en el fichero indicado.



○ Modificar el centinela y ver cómo proceder para detectar dicha alteración.

Para comparar centinelas, lo primero que vamos a hacer es crearlo:

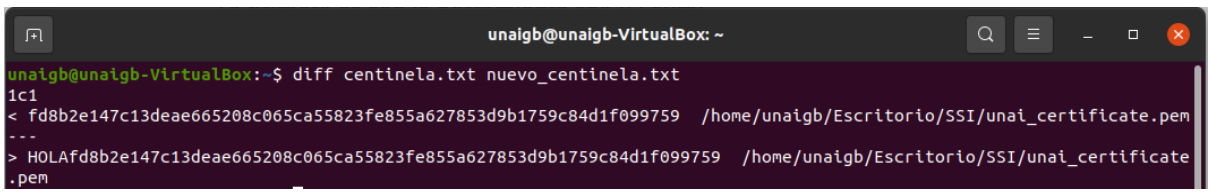




Ahora, vamos a crear otro centinela igual y a modificarlo.



Y vamos a buscar las diferencias entre los dos centinelas:

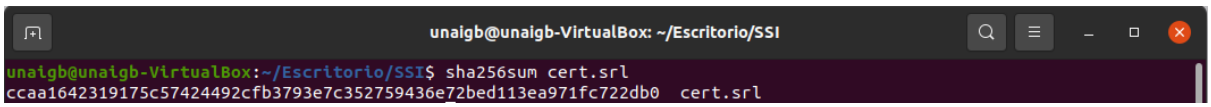


Como vemos, sí que las encuentra.

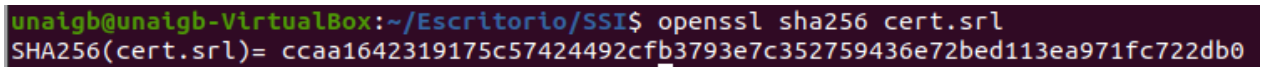
2. Calcular el código hash (p.e. SHA256) de un fichero con tres herramientas diferentes. Comprobar que el resultado es el mismo en los tres casos, que no depende de la herramienta usada.

Ahora vamos a calcular el hash de cert.srl de tres formas distintas.

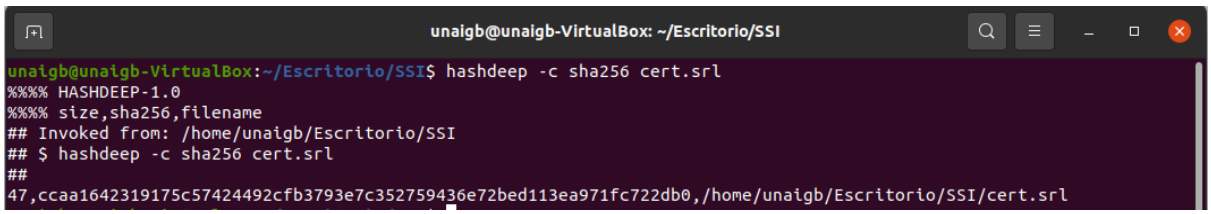
La primera es con la herramienta sha256sum:



Como segunda opción vamos a usar openssl:



Y como última opción vamos a usar hashdeep:



Y como podemos observar, independientemente de la orden utilizada, el hash resultante es el mismo, por lo que se pueden usar cualquiera de las tres herramientas indistintamente.

3. Creación de una contraseña segura

Para la creación de nuestra contraseña segura, vamos a usar el fichero diceware.pdf y un dado.

Para ello, vamos a realizar tiradas combinadas de 5 para obtener un número o palabra en el fichero. En el caso de unix deberemos de fijarnos en el límite máximo de caracteres.

La primera tirada será la siguiente:



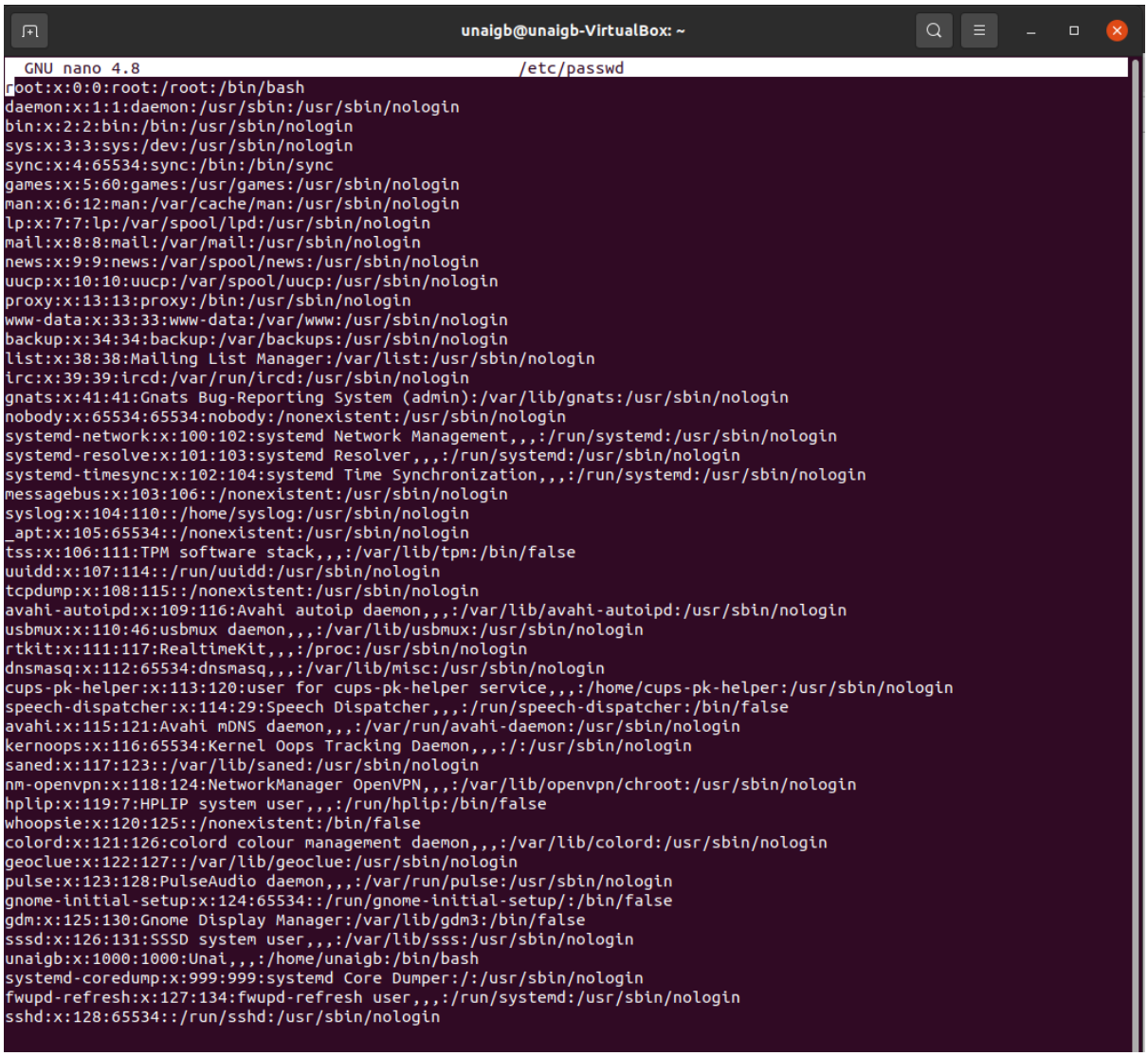
“45423” correspondiente a la palabra “Mazda”, la cual tiene 5 caracteres por lo que la siguiente tirada debe de ser de 3 o menor, debido a las características de Unix (máximo 8 caracteres).



Tras algunas tiradas buscando la mejor seguridad, la siguiente tirada da como resultado “22562” correspondiente a la cadena “s82”, con lo que nuestra nueva contraseña quedaría como “Mazdas82”.

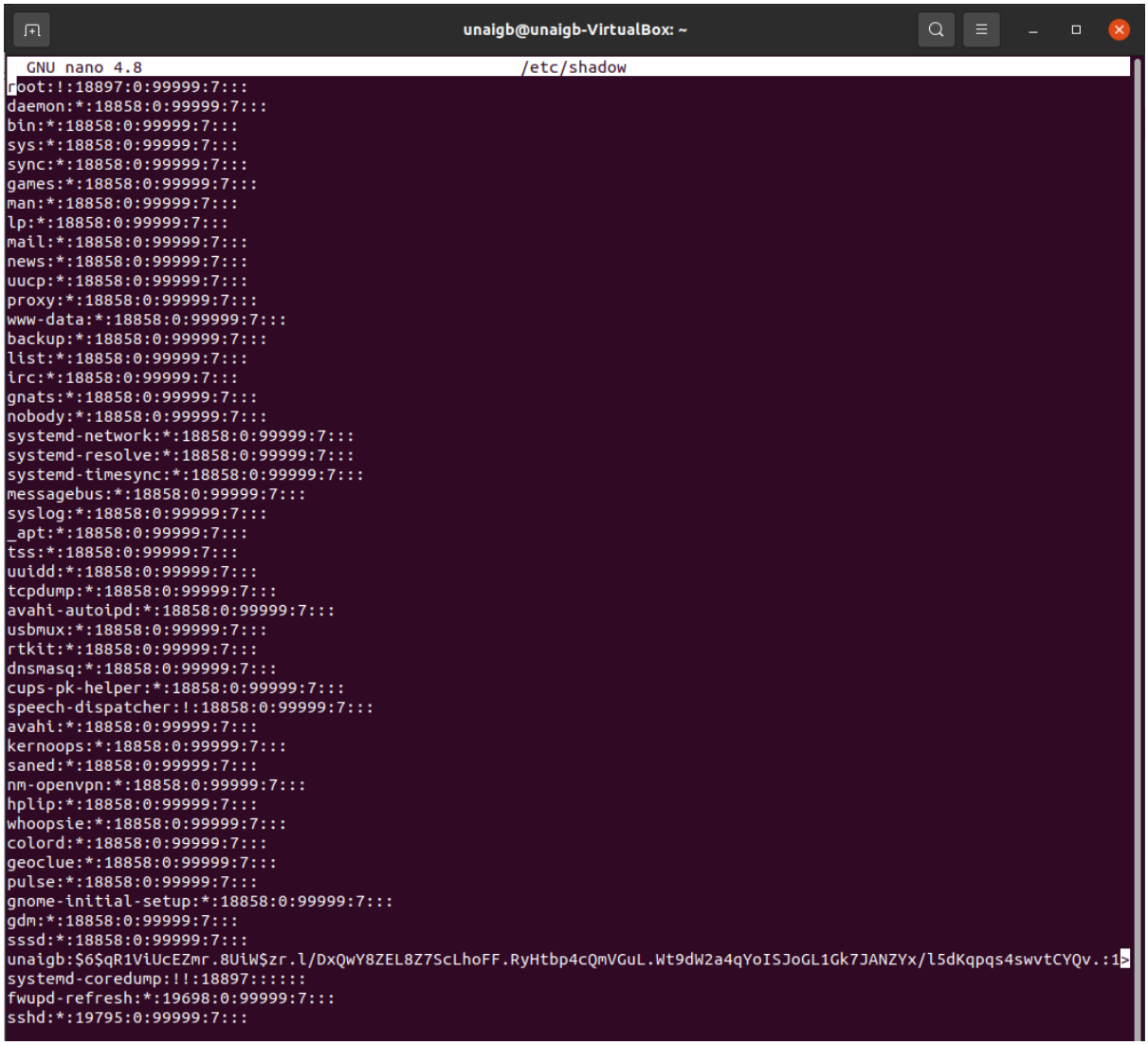
4. Examen de ficheros

En este caso los ficheros a comprobar son los ficheros /etc/passwd el cual contiene la información de las cuentas de usuario del sistema, teniendo como peculiaridad, que al ser un fichero abierto a la lectura, tiene las contraseñas de las cuentas cifradas y almacenadas en el otro fichero, /etc/shadow, al cual solo se puede acceder como root.



Como se puede observar, el campo donde debería de estar la contraseña se encuentra ocupado con una “x”, para así no ofrecer esa información a usuarios sin permisos.

En el fichero shadow, se encuentra la información sobre la contraseña, aunque, obviamente para mayor protección la información se encuentra cifrada:



Siendo la información sobre la contraseña el segundo campo.

5. Contraseñas en Windows

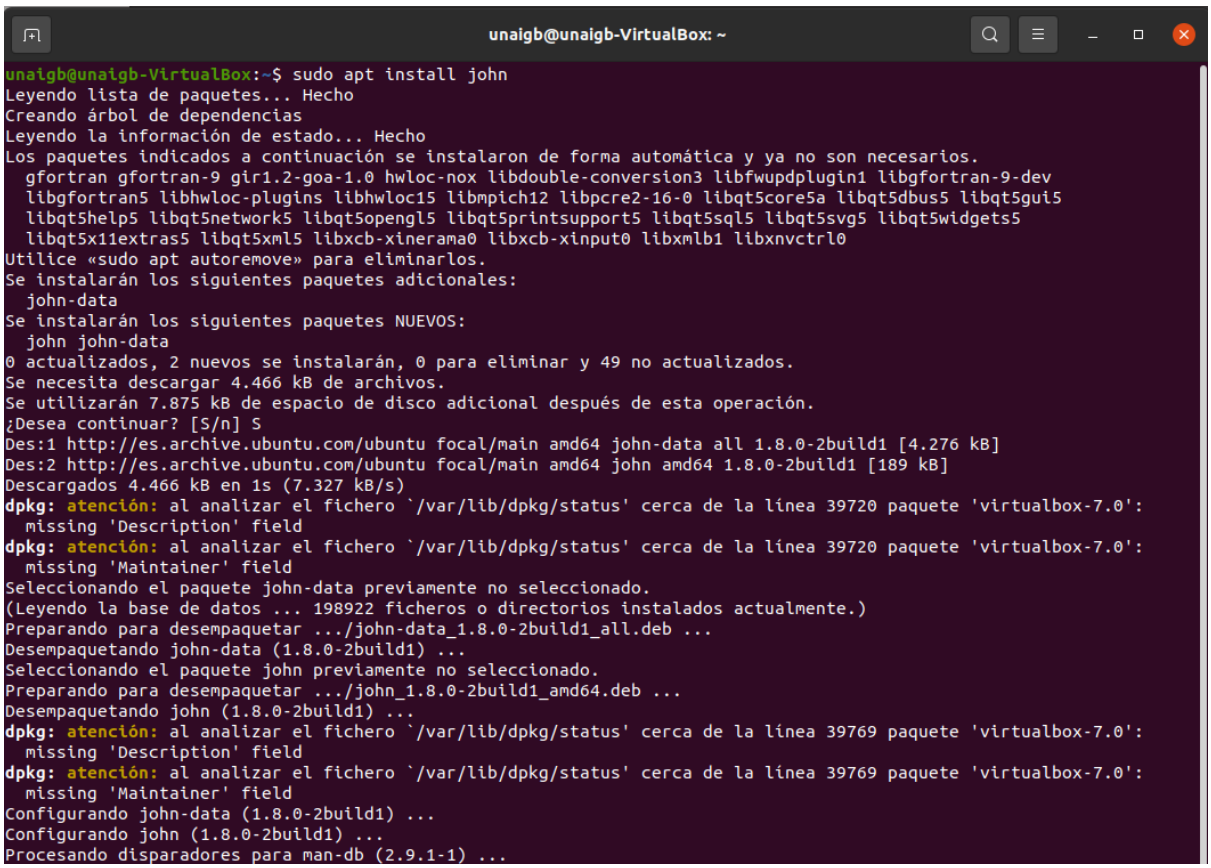
Las contraseñas en Windows se almacenan en el registro del sistema(SAM) en forma de resúmenes de contraseñas hash utilizando algoritmos como NTLM o NTLMv2.

6. Herramientas de auditorías de contraseñas

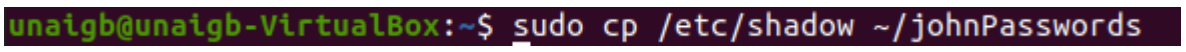
Vamos a instalar y a utilizar dos herramientas que nos permitan recuperar contraseñas.

La primera de ellas es John the Ripper.

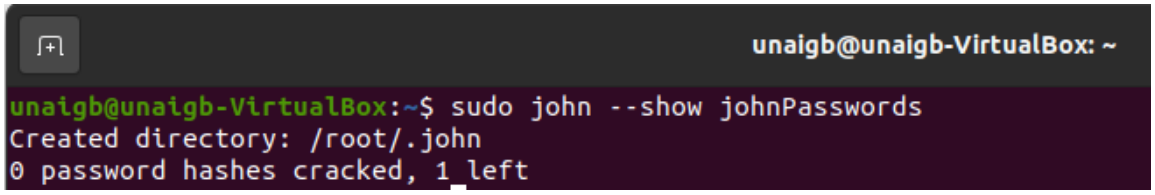
Lo instalamos:



Hacemos una copia del /etc/shadow para hacer la prueba



Y hacemos la prueba con el siguiente comando:



Lo hemos ejecutado sobre la copia del fichero /etc/shadow con permisos de lectura y como se puede ver no muestra nada ya que no ha conseguido descifrar ninguna contraseña disponible.

La segunda herramienta que hemos encontrado ha sido Hydra, por lo que la instalaremos también.

```
unaigb@unaigb-VirtualBox:~$ sudo apt install hydra
```

Ahora crearemos los usuarios para hacer las pruebas:

```
unaigb@unaigb-VirtualBox:~$ sudo passwd usuario1
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
unaigb@unaigb-VirtualBox:~$ sudo useradd usuario2
unaigb@unaigb-VirtualBox:~$ sudo passwd usuario2
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
```

Las contraseñas utilizadas son las siguientes, para el usuario1 → 123456, y para el usuario2 → &Gh*4asHjk!

Para las pruebas con los usuarios usaremos John the ripper y el diccionario rockyou.txt, uno de los más utilizados:

```
unaigb@unaigb-VirtualBox: ~
unaigb@unaigb-VirtualBox:~$ john --wordlist=rockyou.txt ~/hashes.txt
Loaded 2 password hashes with 2 different salts (crypt, generic crypt(3) [?/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
123456           (usuario1)
1g 0:00:04:37 0% 0.003609g/s 462.5p/s 462.9c/s 462.9C/s 01121984..youngdro
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
```

Como podemos comprobar, tras varios minutos de ejecución, la herramienta solo ha conseguido obtener la contraseña del primer usuario (tardó apenas un segundo) y la contraseña del segundo usuario no la pudo encontrar, demostrando así que es una contraseña fuerte.

7. Tablas rainbow

Las rainbow tables son una forma de ataque contra contraseñas que utiliza una técnica conocida como precomputación para invertir funciones de hash. Una tabla arcoíris es una tabla gigante de hash precalculados que se utiliza para buscar rápidamente contraseñas a partir de se hash.

Para crear una tabla, se selecciona un conjunto de contraseñas candidatas, se les aplica una función de hash y se almacena el par contraseña original-hash resultante de la tabla. Este proceso se repite varias veces utilizando técnicas de reducción y cadenas arcoíris para reducir la cantidad de almacenamiento necesario.

Cuando se tiene el hash de una contraseña desconocida se busca ese hash en la tabla arcoíris. Si el hash está presente en la tabla se recupera la contraseña original asociada a ese hash.

Las rainbow tables pueden ser eficaces contra contraseñas débiles y de longitud limitada. Sin embargo las defensas modernas, como el uso de “sal”(valor aleatorio único para cada contraseña antes de aplicar el hash) y funciones de hash más seguras, hacen que las rainbow tables sean menos efectivas.